

SiberGüvenlik

Temel Bilgisayar - Hafta 3



Dijital Kalenizi İnşa Edin: Üniversite Öğrencileri İçin Siber Güvenlik Mimarisi

Dijital güvenlik sadece teknik bir konu değil, yaratıcı kimliğin ve fikri mülkiyetin korunmasıdır.

Bu sunum, üniversite düzeyindeki öğrencilere yönelik olarak temel sorun gidermeden, gelişmiş tehdit modellemelerine kadar geniş bir yelpazeyi kapsar.

Amacımız, tehditleri tanıma ve bunlara karşı proaktif savunma mekanizmaları oluşturmaktır.



Neden Koruyoruz? Fikri Mülkiyetin Değeri

Güvenlik konusunu 'bilgisayarı korumak' yerine 'tasarımlarınızı ve yaratıcı kimliğinizi korumak' olarak çerçevelemeliyiz.

Korunması Gerekenler:

1. Bitmemiş Tasarım Dosyaları (Source files, 3D models).
2. Kişisel Veriler (Öğrenci kimlikleri, akademik çalışmalar).
3. Fikri Mülkiyet ve Ticari Sırlar (Proje fikirleri, prototipler).
4. Repütasyon ve İtibar (Sosyal medya ve e-posta hesapları).

Dijital Tehdit Modeli: Saldırgan Kim?

Tehdit modellemesi, kime karşı ve neyi savunduğumuzu anlamamızı sağlar.
Saldırgan Kategorileri:

- Bireysel Hacker'lar (Maddi kazanç veya meydan okuma).
- Sektörel Casuslar (Tasarım ve proje hırsızlığı).
- Fidyeye Yazılımı Çeteleri (Finansal çıkar için veri şifreleme).
- Devlet Destekli Aktörler (Gelişmiş kalıcı tehditler - APT).

Savunma Katmanları: Derinlemesine Savunma Prensipleri

Tek bir güvenlik önlemi yeterli değildir; birden çok katmanın birleşimi riskleri azaltır.

Katmanlar:

1. Çevre Güvenliği (Ağ güvenliği, Güvenlik Duvarı).
2. Sistem Güvenliği (İşletim sistemi yamaları, Antivirüs).
3. Veri Güvenliği (Şifreleme, Yedekleme).
4. Kullanıcı Eğitimi (Farkındalık, Oltalama tanıma).



Modül 1 Özeti: Temel Sorun Giderme ve Acil Eylemler

Dijital ortamdaki aksaklıkları hızlıca gidermek, iş akışının kesintiye uğramasını engeller.

Temel sorun giderme, genellikle yazılımsal değil, kullanıcı hatası veya basit yapılandırma sorunlarından kaynaklanır.

Bu bölümde, en sık karşılaşılan üç sorunun pratik çözümlerini inceleyeceğiz.

Sık Karşılaşılan Sorun 1: Bilgisayar Dondu/Yavaşladı

'Bilgisayar dondu' durumunda ilk adım Görev Yöneticisi'ni (Task Manager) kullanmaktır.

- Görev Yöneticisi Nasıl Açılır: Ctrl+Shift+Esc veya Ctrl+Alt+Del.
- Yüksek Kaynak Tüketimi: Hangi uygulamanın CPU, Bellek veya Disk kaynaklarını aşırı kullandığını belirleyin.
- Süreci Sonlandırma: Yanıt vermeyen uygulamayı seçin ve 'Görevi Sonlandır' diyerek izole edin.
- Performans Sekmesi: Donanım kısıtlamalarını anlamak için bu sekmeyi analiz edin.



Süreç Yönetimine Akademik Yaklaşım

Bir bilgisayarın yavaşlamasının temel nedenlerinden biri belleğin doğru yönetilememesidir (Memory Leak).

- Bellek Sızıntısı: Bir uygulamanın kullandığı belleği işi bittikten sonra işletim sistemine geri vermemesi.
- Takas Dosyası (Paging File): Fiziksel RAM dolduğunda, işletim sistemi disk alanını kullanmaya başlar, bu da performansı ciddi şekilde düşürür.
- Çözüm: Tarayıcı sekmelerini kısıtlama ve güncel sürücülerini kullanma.

Sık Karşılaşılan Sorun 2: Yazıcı Yazdırmıyor

Yazıcı sorunları genellikle kablo, sürücü veya kağıt sorunlarından kaynaklanır.
Kontrol Listesi:

1. Fiziksel Kontrol: USB kablosunun veya Wi-Fi bağlantısının etkinliğini kontrol edin.
2. Kağıt/Mürekkep Durumu: Kağıt sıkışması veya mürekkep kartuşu seviyelerini kontrol edin.
3. Sürücü Kontrolü: Yazıcının güncel ve doğru sürücüyü kullandığından emin olun. Sürücüyü yeniden yüklemek gerekebilir.
4. Yazdırma Kuyruğu (Spooler): Kuyruğu temizlemek veya yazdırma biriktiricisi hizmetini (Spooler service) yeniden başlatmak işe yarayabilir.

Sık Karşılaşılan Sorun 3: İnternet Yavaş

'İnternet yavaş' sorununda ilk ve en etkili çözüm modem ve yönlendiriciyi yeniden başlatmaktır (Power Cycling).

Neden İşe Yarar:

- IP Çatışmalarını Çözme: Yeniden başlatma, cihazların yeni ve temiz bir IP adresi almasını sağlar.
- Belleği Temizleme: Yönlendiricinin uzun süre çalışmaktan kaynaklanan belleğini temizler.
- Bağlantı Kontrolü: Kablolu bağlantının Cat5e/Cat6 standardında olduğunu kontrol edin.
- Alternatif DNS Kullanımı: Ağ hızını değil, çözünürlük süresini artırmak için Google DNS veya Cloudflare DNS gibi alternatifleri deneyin.

Ağ Sorunlarında Derinlemesine Tanı

Üniversite öğrencileri, ağ sorunlarını daha teknik araçlarla teşhis etmeyi bilmelidir.

- Ping: Cihazınızın ağdaki başka bir cihaza (veya internet sunucusuna) erişip erişemediğini ve gecikme süresini (latency) ölçer.
- Traceroute/Tracert: Veri paketlerinizin hedefine ulaşana kadar geçtiği tüm yönlendiricileri (hop) listeler. Tıkanıklığın nerede olduğunu gösterir.
- IPConfig/IFConfig: Cihazınızın mevcut IP adresi, alt ağ maskesi ve ağ geçidi bilgilerini görmenizi sağlar.



Modül 2: Parola: Dijital Kalenizin Anahtarı

Parolalar, dijital kimliğimizin ilk ve en kritik savunma hattıdır. Bir parola ne kadar karmaşık ve uzunsa, kırılması o kadar zor olur (Entropy prensibi). Ortalama bir saldırganın denediği parolaları kırmak için gereken süre, parolanın uzunluğuyla üstel olarak artar. Hedef: Brute-Force ve sözlük saldırılarına karşı koyacak parolalar oluşturmak.

MODA TASARIMI

M0d4 T454r!M!

Güçlü Parola Oluşturma Teknikleri

Güçlü bir parola, uzunluk ve karakter çeşitliliğini birleştirir.

Parola Kriterleri:

- Uzunluk: Minimum 12-16 karakter idealdir.
- Çeşitlilik: Büyük harfler, küçük harfler, rakamlar ve özel karakterler kullanılmalıdır.
- Rastgelelik: Tahmin edilebilir bilgileri (isim, doğum tarihi) içermemelidir.
- Parola Cümlesi: Birbirinden bağımsız kelimeleri birleştirerek uzun ve akılda kalıcı parolalar oluşturmak (Örnek: Tr1lyon\$ar1KirmiziKedi!).

Parola Kırma Yöntemleri

Saldırganlar, parolaları kırmak için sadece deneme yanılma yapmaz, gelişmiş algoritmalar kullanır.

- Sözlük Saldırısı (Dictionary Attack): Yaygın kelimeleri ve kombinasyonları dener.
- Brute-Force: Olası her karakter kombinasyonunu dener.
- Gökkuşağı Tabloları (Rainbow Tables): Parola özetlerinin (hash) önceden hesaplanmış veritabanlarıdır, hashlenmiş parolaları hızlıca tersine çevirmek için kullanılır.



Parola Yöneticileri: Neden Kullanmalıyız?

Parola yöneticileri, her hesap için benzersiz, karmaşık parolalar oluşturmayı ve güvenli bir şekilde depolamayı sağlar.

- Tek Ana Anahtar (Master Key): Tüm parolalarınız, sadece sizin bildiğiniz tek bir ana parola ile şifrelenmiş bir kasada tutulur.
- Kullanım Kolaylığı: Çoğu yönetici, web tarayıcınıza veya uygulamalara otomatik doldurma yeteneği sunar.
- Güvenlik: Veriler, AES-256 gibi güçlü algoritmalar kullanılarak yerel olarak şifrelenir.

Hashleme ve Tuzlama (Salting): Parolaların Arkasındaki Bilim

Güvenilir sistemler, parolaları asla düz metin olarak saklamaz, bunun yerine özet (hash) değerlerini tutar.

- Hash Fonksiyonu: Parolayı geri döndürülemez, sabit uzunlukta bir dizeye dönüştürür (Örn: SHA-256).
- Tuzlama (Salting): Aynı parolaya sahip kullanıcıların aynı hash değerini üretmesini önlemek için, her parolaya rastgele bir değer (salt) eklenir. Bu, gökkuşağı tablolarını etkisizleştirir.



Çok Faktörlü Kimlik Doğrulama (MFA/2FA)

MFA, bir kullanıcının kimliğini doğrulamak için iki veya daha fazla bağımsız kanıt gerektirir.

Faktör Türleri:

1. Bilgi Faktörü (Knowledge): Parola, PIN (Bildiğiniz şey).
2. Sahip Olma Faktörü (Possession): Telefon, güvenlik anahtarı (Sahip olduğunuz şey).
3. Biyometrik Faktör (Inherence): Parmak izi, yüz tanıma (Olduğunuz şey).

MFA, çalınan bir parolanın tek başına yeterli olmasını engeller.

Zaman Tabanlı Tek Kullanımlık Parolalar (TOTP)

TOTP, genellikle bir doğrulama uygulaması (Authenticator app) tarafından 30 saniyelik aralıklarla üretilen kodlardır.

- Güvenlik Avantajı: SMS tabanlı 2FA, Sim Swap saldırılarıyla tehlikeye atılabilir. TOTP, cihaz tabanlı olduğu için bu riski azaltır.
- Mekanizma: Hem sunucunun hem de kullanıcının paylaşılan bir gizli anahtarı ve zaman damgasını kullanarak aynı kodu üretmesine dayanır.
- En İyi Pratik: Donanımsal güvenlik anahtarları (Yubikey) en yüksek korumayı sağlar.



Parola Yenileme Stratejileri ve İhlal Yanıtı

Eğer kullandığınız bir hizmetin veri tabanı ele geçirildiyse, parolanızı hemen değiştirmelisiniz.

- Have I Been Pwned gibi araçlar, e-posta adresinizin bilinen ihlallerde yer alıp almadığını kontrol etmeye yardımcı olur.
- Asla parolaları yeniden kullanmayın. Bir sitede çalınan parola, diğer hesaplarınızı da riske atar.
- İhlal sonrası, ilgili hesaptaki tüm güvenlik sorularını ve kurtarma e-postalarını da kontrol edin.



Modül 3: Zararlı Yazılımlar (Malware) Anatomisi

Zararlı yazılımlar (Malware), bilgisayar sistemlerine zarar vermek veya izinsiz erişim sağlamak için tasarlanmış tüm yazılımları kapsar. Tasarım öğrencileri için risk yüksektir, çünkü tasarım dosyaları (CAD, proje dosyaları) yüksek değere sahiptir ve fidye yazılımlarının birincil hedefidir.

Virüsler: Kendini Çoğaltan Kodlar

Bilgisayar virüsleri, meşru bir programa veya dosyaya kendilerini iliştirerek çalışır ve konak program çalıştığında yayılır.

- Çalışma Mekanizması: Virüs, dosyanın orijinal kodunu bozar ve kötü amaçlı kodu sisteme enjekte eder.
- Solucanlar (Worms): Virüslerin aksine, solucanlar kendi başlarına çalışabilir ve ağ üzerinden otomatik olarak çoğalabilirler. Genellikle sistem zafiyetlerini kullanırlar.

Truva Atları (Trojans) ve Arka Kapılar (Backdoors)

Truva Atı, kullanıcının faydalı veya masum sandığı bir yazılımın içine gizlenmiş kötü amaçlı kod parçasıdır. Kendi kendine çoğalmaz.

- Yöntem: Öğrenci bir tasarım yazılımının 'crack'li sürümünü indirdiğinde, aslında Truva Atını sisteme sokabilir.
- Arka Kapı (Backdoor): Bir Truva Atı, genellikle saldırganın gelecekte sisteme gizlice erişmesi için bir arka kapı oluşturur.

Casus Yazılımlar (Spyware) ve Keylogger'lar

Casus yazılımlar, kullanıcının bilgisi veya izni olmadan etkinlikleri izlemek ve kişisel bilgileri toplamak için tasarlanmıştır.

- Keylogger'lar: Klavyede basılan her tuşu kaydeder. Parolaları, kredi kartı bilgilerini ve e-posta içeriklerini çalabilir.
- Bilgi Hırsızları (Infostealers): Tarayıcı geçmişini, kayıtlı parolaları ve sistem yapılandırmalarını toplar.
- Tehlike: Özellikle akademik ve finansal kimlik bilgileri için büyük risk oluşturur.



Fidye Yazılımları (Ransomware): Mekanizma ve Etkisi

Fidye yazılımları, kullanıcının dosya ve verilerini şifreleyerek erişimi engeller ve karşılığında fidye (genellikle kripto para cinsinden) talep eder.

- Tasarım Dosyalarına Etkisi: Yüksek çözünürlüklü tasarım dosyaları (PSD, AI, CAD) büyük hedeflerdir. Kilitlendiklerinde, öğrencinin tüm projesi tehlikeye girer.
- Çalışma Şekli: Genellikle güçlü asimetrik şifreleme algoritmaları (AES ve RSA kombinasyonu) kullanır.

Ransomware'den Korunma ve Kurtarma Stratejisi

En iyi savunma yedeklemedir. Fidyeye ödemek, saldırganları teşvik eder ve verilerin geri alınacağını garanti etmez.

Korunma:

1. 3-2-1 Yedekleme Kuralı: Verinin 3 kopyası, 2 farklı ortamda, 1 kopyası çevrimdışı (off-site/cold storage) tutulmalıdır.
2. Güncellemeler: İşletim sistemi ve uygulamaları güncel tutmak, bilinen zafiyetlerin kullanılmasını engeller.
3. Dosya İzinleri: Önemli dosyaların sadece okunabilir (read-only) olmasını ayarlamak.

Rootkitler: Sistemin Gizli Ustaları

Rootkitler, zararlı yazılımların ve saldırganların sistemde tespit edilmeden kalmasını sağlayan yazılımlardır.

- Gizlenme Yeteneği: İşletim sistemi çekirdek düzeyinde çalıştıkları için, normal güvenlik araçları onları tespit edemez.
- Amaç: Saldırganlara sürekli ve gizli 'root' (en yüksek yetki) erişimi sağlamaktır.
- Tespit Zorluğu: Genellikle sistemin davranışını analiz eden özel araçlarla veya formatlama yoluyla temizlenirler.



Gelişmiş Kalıcı Tehditler (APT) ve Hedefli Saldırıları

- APT'ler, yüksek yetenekli gruplar tarafından (genellikle devlet destekli) belirli bir kurumu veya kişiyi hedef alan, uzun soluklu ve çok aşamalı siber saldırılardır.
- Özellikleri: Sisteme sızdıktan sonra yıllarca fark edilmeden kalabilir ve küçük veri sızıntıları yoluyla bilgi toplarlar.
 - Üniversite Riskleri: Akademik araştırmalar, patentler veya kritik altyapı bilgileri hedef olabilir.
 - Savunma: Sıfır Güven (Zero Trust) mimarisi gereklidir.

Antivirüs Yazılımları: Savunma Kalkanlarınız

Antivirüs yazılımları, sistemi bilinen veya şüpheli zararlı yazılımlara karşı tarar ve korur.

- İmza Tabanlı Tespit: Antivirüs, bilinen kötü amaçlı yazılımların dijital parmak izini (imzasını) veritabanındaki kayıtlarla karşılaştırır.
- Sezgisel (Heuristic) Tespit: Yeni ve bilinmeyen zararlı yazılımları, kod davranışlarını analiz ederek tespit etmeye çalışır. Bu, sıfır-gün (zero-day) saldırılarına karşı önemlidir.
- Gerçek Zamanlı Koruma: Dosyalar açılmadan önce taranarak yayımları engellenir.



Sıfırncı Gn (Zero-Day) Aıkları ve Yama Ynetimi

Sıfırncı Gn Aıęı, yazılım geliřtiricisi tarafından henz bilinmeyen veya yama yayınlanmamıř gvenlik zafiyetleridir. Bu aıklar, saldırganlar iin kritik bir avantaj saęlar.

- Gncel Tutma: İřletim sistemi ve programları gncel tutmak, bilinen zafiyetlerin kapatılmasının tek yoludur.
- Yama Ynetimi: Gvenlik yamalarını test etmek ve mmkn olan en kısa srede kurmak zorunludur. Otomatik gncellemeler tercih edilmelidir.



Sandbox (Korumalı Alan) Teknolojisi

Sandbox, şüpheli programları veya dosyaları, sistemin geri kalanından izole edilmiş güvenli bir ortamda çalıştırma yöntemidir.

- Amaç: Zararlı bir kodun sistem dosyalarına veya çekirdeğe zarar vermeden davranışını gözlemlemek.
- Kullanım Alanları: Tarayıcılar (chrome, firefox), sanal makineler ve gelişmiş güvenlik yazılımları bu teknolojiyi kullanır.
- Avantaj: Bilinmeyen tehditlerin (Zero-day) etkisini sıfırlar.



Olay Yanıtı (Incident Response) Temelleri

Saldırı gerçekleştiğinde paniklemek yerine, sistematik bir olay yanıtı planı izlenmelidir.

Adımlar:

1. Hazırlık (Yedekleme, plan oluşturma).
2. Tespit ve Analiz (Saldırının kapsamını belirleme).
3. Kısıtlama (Ağı izole etme, bilgisayarın fişini çekme).
4. Ortadan Kaldırma (Zararlı yazılımı temizleme).
5. Kurtarma (Yedeklerden geri yükleme).
6. Alınan Dersler (Sistemi güçlendirme).

Modül 4: İnternet ve Ağ Güvenliği Mimarisi

İnternet, bilgiye erişim sağlarken aynı zamanda güvenlik açıklarının da kaynağıdır. Ağ trafiğini doğru anlamak, savunma için önemlidir. Üniversite ortamında, paylaşılan ağlar ve kamuya açık Wi-Fi noktaları özel dikkat gerektirir.



HTTPS'nin Önemi: Güvenli Web Siteleri

Güvenli siteler 'https:/' ile başlar ve tarayıcıda bir kilit simgesi görünür. HTTPS, Tarama Katmanı Güvenliği (TLS) protokolünü kullanarak istemci (tarayıcı) ve sunucu arasındaki tüm iletişimi şifreler.

- Avantajı: Veri paketleri üçüncü bir kişi tarafından dinlense bile (man-in-the-middle), içerik okunamayacaktır.
- TLS El Sıkışması: Güvenli bağlantıyı kurmak için istemci ve sunucu arasında gerçekleşen kriptografik doğrulama sürecidir.



Sertifika Yetkilileri (CA) ve Güven Zinciri

Bir web sitesinin HTTPS kullanabilmesi için bir Sertifika Yetkilisinden (CA) dijital sertifika alması gerekir.

- CA'nın Rolü: Web sitesinin iddia ettiği kişi olduğunu doğrular ve sertifikayı imzalar.
- Güven Zinciri: Tarayıcınız, sertifikanın güvenilir bir CA tarafından imzalandığını kontrol eder. Bu zincir bozulursa, tarayıcı uyarı verir.
- Hata Mesajları: Sertifika geçerli değilse veya süresi dolduysa, asla siteye giriş yapmayın.



Açık Wi-Fi Ağlarının Tehlikeleri

Halka açık ağlar (kafe, havaalanı, kampüs dışı) genellikle şifrelemesizdir ve büyük risk taşır.

- MiTM Saldırısı: Saldırgan, sizin cihazınız ile internet arasında konumlanarak tüm trafiği okuyabilir ve hatta değiştirebilir.
- Sahte Erişim Noktaları: Saldırganlar, meşru gibi görünen sahte Wi-Fi ağları kurarak kullanıcıları tuzağa düşürebilir.
- Çözüm: Açık Wi-Fi kullanırken her zaman VPN kullanın.

Sanal Özel Ağlar (VPN) ve Tünelleme

VPN, kullanıcının cihazı ile VPN sunucusu arasında şifreli bir 'tünel' oluşturarak veri güvenliğini sağlar.

- Fonksiyon: Tüm internet trafiğiniz şifrelenir ve sunucu üzerinden geçer. Bu, yerel ağ sağlayıcınızın veya saldırganların verilerinizi görmesini engeller.
- IP Adresi Gizleme: Gerçek IP adresiniz yerine VPN sunucusunun IP adresi görünür, bu da coğrafi konum tabanlı takibi zorlaştırır.
- Protokoller: OpenVPN, WireGuard gibi güvenilir VPN protokolleri tercih edilmelidir.



Güvenlik Duvarları (Firewalls) Nasıl Çalışır?

Güvenlik duvarı, önceden tanımlanmış kurallar setine dayanarak gelen ve giden ağ trafiğini kontrol eder ve filtreler.

Türler:

- Paket Filtreleme: Her veri paketini ayrı ayrı inceler (Kaynak IP, Hedef Port vb.).
- Durumsal İnceleme (Stateful Inspection): Paketin, hali hazırda devam eden meşru bir oturumun parçası olup olmadığını kontrol eder. Daha güvenlidir.
- Uygulama Katmanı Güvenlik Duvarları: Hangi uygulamanın hangi trafiği oluşturduğunu derinlemesine inceler.

Tarayıcı Güvenliği ve Ayarları

- Tarayıcı, dış dünyaya açılan ana kapımızdır ve güvenliği kritik öneme sahiptir.
- Uzantılar (Extensions): Sadece güvenilir kaynaklardan eklentiler yükleyin. Aşırı izin isteyen uzantılar büyük risk taşır.
 - Gizlilik Modu: İzlenmeyi azaltır ancak IP adresinizi gizlemez.
 - Güncellemeler: Tarayıcınızı her zaman en son sürüme güncelleyin; tarayıcılar sık sık güvenlik yamaları alır.



Çerezler (Cookies) ve Dijital Takip Mekanizmaları

Çerezler, web sitelerinin tarayıcınızda depoladığı küçük bilgi parçalarıdır.

- Birinci Taraf Çerezleri: Oturumunuzu korumak için kullanılır (Giriş bilgileriniz).
- Üçüncü Taraf Çerezleri: Farklı web siteleri arasında sizi takip eden reklam ve analitik şirketleri tarafından kullanılır. Bu çerezler gizlilik ihlali potansiyeli taşır.
- Çözüm: Üçüncü taraf çerezleri engellemek ve çerez izinlerini düzenli olarak temizlemek.



Alan Adı Sistemi (DNS) Güvenliği

DNS, web sitelerinin isimlerini (örneğin google.com) IP adreslerine çeviren telefon rehberidir.

- DNS Zehirlenmesi (Spoofing): Saldırgan, DNS sunucusuna sahte bilgi enjekte ederek kullanıcıları sahte (phishing) sitelere yönlendirir.
- DNS over HTTPS (DoH) / DNS over TLS (DoT): İstemci ile DNS sunucusu arasındaki sorguları şifreleyerek zehirlenmeyi zorlaştırır ve gizliliği artırır.

IoT (Nesnelerin İnterneti) Cihazlarının Güvenliği

Akıllı cihazlar (kameralar, termostatlar, akıllı saatler) ağımıza yeni güvenlik açıkları ekler.

- Varsayılan Parolalar: Birçok IoT cihazı fabrika çıkışı kolay tahmin edilebilir parolalarla gelir. Bunları hemen değiştirmek zorunludur.
- Güncelleme Eksikliği: Birçok IoT cihazı düzenli güvenlik güncellemesi almaz.
- Ağ Segmentasyonu: IoT cihazlarını, ana bilgisayarlarınızın ve hassas verilerinizin bulunduğu ana ağdan ayırmak önemlidir.

Modül 5: Oltalama (Phishing) ve Sosyal Mühendislik

Teknolojinin yetersiz kaldığı yerde, saldırganlar insan psikolojisini hedefler. Sosyal mühendislik, manipülasyonla bilgi çalma sanatıdır. Oltalama (Phishing), sahte e-postalar veya mesajlar aracılığıyla kullanıcıları kandırıp kritik bilgilerini (parola, kredi kartı) elde etme girişimidir.

no-reply@microsoft.com

no-reply@rnmicrosoft.com

Standart Oltalama (Phishing) Nedir?

- Standart oltalama, çok sayıda kişiye gönderilen ve genellikle banka veya popüler bir hizmetten geliyormuş gibi görünen genel e-postalardır.
- Kullanılan Taktikler: Aciliyet hissi yaratmak ('Hesabınız kilitlenecek!'), korku uyandırmak veya ödül vaat etmek.
 - Amaç: Kullanıcıyı sahte bir giriş sayfasına yönlendirerek kimlik bilgilerini girmek için kandırmak.

Oltalama Türleri 1: Hedefe Yönelik Saldırılar

Hedefe yönelik saldırılar çok daha tehlikelidir çünkü kişisel bilgi ve bağlam içerirler.

- Spear Phishing (Mızrak Oltalaması): Belirli bir kişiyi veya küçük grubu hedef alır. E-posta, kişinin çalıştığı kurumun veya tanıdığı birinin dilini taklit eder.
- Whaling (Balina Avcılığı): Üst düzey yöneticileri (CEO, Dekan) hedef alan yüksek profilli spear phishing türüdür. Finansal olarak en büyük hasarı verme potansiyeline sahiptir.

Oltalama Türleri 2: Vishing ve Smishing

- Phishing sadece e-posta ile sınırlı değildir; diğer iletişim kanallarını da kullanır.
- Vishing (Voice Phishing): Telefon araması yoluyla yapılır. Saldırgan, genellikle teknik destek veya banka temsilcisi gibi davranır.
 - Smishing (SMS Phishing): Metin mesajları aracılığıyla kötü amaçlı bağlantılar gönderilir. Özellikle mobil cihazlarda dikkat dağınıklığı nedeniyle etkilidir.
 - Ortak Nokta: Tüm bu türler, sahte bir aciliyet duygusu yaratır.

Sahte Bir E-postayı Nasıl Tanırırsınız? (Bölüm 1)

Sahte e-postaları tanımak için dikkatli bir analiz gereklidir.

- Gönderen Adresi: Adres, meşru şirketin alan adıyla (domain) birebir eşleşmeli mi? (Örn: 'apple.com' yerine 'apple.com').
- Selamlama: Meşru şirketler genellikle isimle hitap ederken, ortalama e-postaları 'Değerli Müşterimiz' gibi genel ifadeler kullanır.
- Dil ve Gramer Hataları: Profesyonel şirketler ciddi dilbilgisi hataları yapmazlar. Düşük kaliteli çeviriler şüphelidir.

Sahte Bir E-postayı Nasıl Tanırırsınız? (Bölüm 2)

Köprüler, ortalama saldırılarının ana taşıyıcısıdır.

- Köprü Kontrolü: Bağlantıya tıklamadan önce fare imlecini köprünün üzerinde tutun. Görünen URL, sizi yönlendirmesi gereken URL ile aynı mı? (Farklı domain adı kullanılmış mı?).
- Duygusal Tetikleyiciler: E-posta, 'hemen şimdi', 'hesabınız askıya alındı', 'yasal işlem' gibi aşırı aciliyet veya tehdit içeren ifadeler içerir.
- Güvenlik Uygulaması: Şüpheli eklentileri kesinlikle açmayın.

E-posta Eklentilerinin Riski ve Makrolar

Gelen e-posta eklentileri (özellikle beklenmedik olanlar), zararlı yazılım dağıtımının yaygın bir yoludur.

- Tehlikeli Uzantılar: .exe, .scr, .zip, .js gibi çalıştırılabilir veya arşivlenmiş dosyalar risklidir.
- Makro Kötüye Kullanımı: Word veya Excel gibi ofis belgeleri (docx, xlsx), kullanıcıdan 'İçeriği Etkinleştir' (Enable Content) düğmesine tıklamasını isteyerek kötü amaçlı makroları çalıştırabilir.
- Kural: Beklenmeyen hiçbir eklentiye açmayın veya indirmeyin.



Sosyal Mühendisliğin Psikolojisi

Saldırganlar, manipülasyon için Cialdini'nin İkna Prensipleri gibi psikolojik yöntemleri kullanır.

- Pretexting (Ön Metin Oluşturma): Saldırganın, kimliğini doğrulayacak sahte bir hikaye veya senaryo uydurması.
- Karşılıklılık (Reciprocity): Önce küçük bir iyilik yaparak hedefin daha sonra daha büyük taleplere 'evet' demesini sağlamak.
- Otorite: Kendini bir yönetici, teknik destek uzmanı veya yasal otorite gibi göstererek hedefin güvenini kazanmak.

İş E-postası Güvenliğinin İhlali (BEC)

BEC saldırıları, e-posta sistemlerine sızarak veya taklit ederek, genellikle para transferi veya hassas veri sızıntısı talep eden saldırılardır.

- Senaryo: Bir tasarım stüdyosunun muhasebe departmanına, CEO'dan geliyormuş gibi görünen acil bir ödeme talimatı gönderilmesi.
- Savunma: Finansal talimatları her zaman e-posta dışı (telefon veya yüz yüze) yöntemlerle doğrulamak.



Örnek Uygulama: Oltalama Senaryosu Analizi

Öğrencilere birkaç sahte e-posta örneği gösterilerek hangilerinin oltalama saldırısı olabileceğini tartışmak faydalıdır.

- Senaryo Analizi: Bir üniversite öğrencisine, 'Öğrenci Kayıt Ücretini Ödemezseniz Kaydınız Silinecek' başlıklı bir e-posta gelir.
- Şüpheli Noktalar: Gönderen alan adı '@gmail.com' veya '@uni-edu.net' olabilir (Gerçek üniversite alan adı yerine). Bağlantı, IP adresi içeren bir web sitesine yönlendirir.



Modül 6: Proaktif Güvenlik ve Uzun Vadeli Stratejiler

Dijital güvenlik bir kerelik bir iş değil, sürekli bir süreçtir. Proaktif adımlar, riskleri minimuma indirir.

Öğrenciler, kendi güvenlik duruşlarını düzenli olarak değerlendirmelidir.



İşletim Sistemi (OS) ve Uygulama Güncellemeleri

Güncellemeler sadece yeni özellikler getirmez, aynı zamanda kritik güvenlik yamalarını (patch) da içerir.

- Neden Erteleme: Her gecikme, saldırganların bilinen zafiyetleri kullanma süresini artırır.
- Otomatik Güncelleme: Mümkün olduğunca işletim sistemi ve kritik uygulamalar için otomatik güncellemeleri etkinleştirin.
- Sürücüler: Donanım sürücülerini de güncel tutmak, özellikle çevre birimlerindeki güvenlik açıklarını kapatır.



Veri Şifrelemesi: Hareket Halindeki ve Bekleyen Veri

Şifreleme, verilerin yetkisiz erişim durumunda okunamaz hale getirilmesidir.

- Bekleyen Veri (At Rest): Sabit diskin tamamının veya hassas klasörlerin şifrlenmesi (BitLocker, FileVault).
- Hareket Halindeki Veri (In Transit): İnternet üzerinden iletilen verilerin şifrlenmesi (HTTPS, VPN).
- Kayıp/Çalınma Riski: Dizüstü bilgisayarınız çalınsa bile, disk şifrelemesi verilerinizin korunmasını sağlar.

Bulut Depolama Güvenliği (Cloud Security)

Bulut hizmetleri (Google Drive, Dropbox) kullanışlıdır ancak kullanıcı da güvenlikten sorumludur.

- Paylaşılan Sorumluluk Modeli: Bulut sağlayıcısı altyapıyı korur, ancak kullanıcı veriyi (kimlik doğrulama, erişim izinleri ve veri şifrelemesi) korumaktan sorumludur.
- Erişim İzinleri: Dosyaları paylaştığınızda 'Herkes'e açık' yerine belirli kişilerle paylaşımı tercih edin.
- MFA Zorunluluğu: Bulut hesabınızda her zaman MFA kullanın.

Mobil Cihaz Güvenliđi

Mobil cihazlar, en çok veri ve en çok kimlik bilgisi taşıyan cihazlardır, bu yüzden korunmaları kritik öneme sahiptir.

- Uygulama İzinleri: Uygulamaların istediđi izinleri dikkatlice inceleyin (Örn: Hesap makinesinin konuma neden ihtiyacı olsun?).
- Biyometrik Kilitler: Parmak izi veya yüz tanıma kullanın, ancak güçlü bir yedek parola bulundurun.
- Uzaktan Silme (Remote Wipe): Cihaz kaybolursa veya çalınırsa verileri uzaktan silme özelliđini etkinleştirin.



Dijital Ayak İzi Yönetimi

Dijital ayak iziniz, internette bıraktığınız tüm veri ve eylemlerin toplamıdır. Sosyal mühendislik saldırıları için yem olabilir.

- Pasif Ayak İzi: Sizin haberiniz olmadan toplanan veriler (IP adresleri, tarama geçmişi).
- Aktif Ayak İzi: Kendi isteğinizle paylaştığınız veriler (Sosyal medya gönderileri, blog yorumları).
- Kısıtlama: Sosyal medya gizlilik ayarlarını düzenli olarak gözden geçirin ve kişisel bilgileri (ev adresi, telefon) mümkün olduğunca az paylaşın.



Güvenlik Testleri: Etik Hacking Kavramları

Etik hacking (Penetrasyon Testi), bir sistemi yasal yollarla hackleyerek zafiyetleri tespit etme sürecidir.

- Üniversite Öğrencisi İçin Önemi: Kendi sisteminizin veya projelerinizin güvenlik açıklarını bulmayı öğrenmek.
- Zafiyet Tarayıcıları: Otomatik araçlar kullanarak yaygın güvenlik açıklarını kontrol edin.
- En Zayıf Halka: Her zaman sistemdeki en zayıf noktanın nerede olduğunu belirleyin (Genellikle kullanıcı veya eski bir yazılım).



Telif Hakları ve Dijital Güvenlik İlişkisi

Tasarımcılar ve yaratıcılar için eserlerinin dijital güvenliği aynı zamanda telif haklarının korunması anlamına gelir.

- İzinsiz Kullanım: Güvenlik ihlali, telifli tasarım dosyalarının çalınmasına ve izinsiz yayılmasına neden olabilir.
- Dijital Filigranlama (Watermarking): Tasarım dosyalarınıza görünmez veya görünür filigran ekleyerek mülkiyetinizi belirtin.
- Lisans Yönetimi: Yazılımlarınızın lisanslarını güvenli bir şekilde saklayın; korsan yazılım kullanmak sisteminizi riske atar.

Finansal Güvenlik ve Güvenli Alışveriş

Çevrimiçi alışveriş yaparken sadece HTTPS kullanan siteleri tercih edin.

- Sanal Kartlar: Ana kredi kartı limitinizden bağımsız, tek kullanımlık veya düşük limitli sanal kartlar kullanın.
- Adres Çubuğu Kontrolü: Ödeme sırasında URL'nin hala meşru satıcının alan adında olduğunu kontrol edin.
- Kamu Bilgisayarları: Hassas finansal işlemler asla ortak veya kamuya açık bilgisayarlarda yapılmamalıdır.



Geleceğin Tehditleri: Yapay Zeka ve Siber Güvenlik

Siber güvenlik alanı sürekli gelişiyor; yapay zeka hem savunma hem de saldırı amaçlı kullanılıyor.

- AI Destekli Oltalama: Yapay zeka, yüksek oranda kişiselleştirilmiş ve gramer hatasız sahte e-postalar (Advanced Spear Phishing) oluşturabilir.
- Otomatik Zafiyet Keşfi: Saldırganlar, AI'yı kullanarak sistemlerdeki bilinmeyen zafiyetleri daha hızlı bulabilir.
- Savunma Tarafında AI: Siber güvenlik ürünleri, anormallikleri tespit etmek ve tehditleri otomatik olarak engellemek için AI/Makine Öğrenimi kullanır.

Özet: Dijital Güvenlik Kontrol Listesi

Kalenizi her gün korumak için uygulamanız gereken temel adımlar:

1. Parolalarınızı ve MFA'yı kontrol edin.
2. İşletim sistemi ve program güncellemelerini yapın.
3. Kritik verilerinizi çevrimdışı yedekleyin (3-2-1 Kuralı).
4. Şüpheli e-postaları her zaman doğrulayın (Ortalama testi).
5. Tarayıcılarınızı ve ağ trafiğinizi kontrol edin (HTTPS).

Sözlük ve Kaynaklar

Bu sunumda geçen bazı temel terimler:

- Ransomware: Fidyeye yazılımı.
- Phishing: Oltalama.
- APT: Gelişmiş Kalıcı Tehdit.
- TLS: Taşıma Katmanı Güvenliği (HTTPS'nin temeli).
- Entropy: Bir parolanın rastgelelik ve tahmin edilemezlik ölçüsü.

Sorularınız

Dijital güvenlik, aktif katılım ve sürekli öğrenme gerektiren dinamik bir alandır. Sorularınız ve görüşleriniz bu konunun daha iyi anlaşılmasına katkı sağlayacaktır.



Güvenlik

Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

